

Cloud Infrastructure and Configuration

Document field	Value
Document owner	FortVault
Intended audience	FortVault's ISO 27001 implementation partner
Classification	Confidential
Evidence basis	Management-provided current-state description
Verification status	Not independently verified against cloud-console exports
Version	0.1
Date	August 28, 2026

1. Scope and Evidence Basis

This document records the production cloud configuration described by FortVault management. It is a current-state configuration summary, not proof that each control operated effectively. The full AWS account identifier, private addresses, hostnames, endpoint URLs, credentials, and secret values are intentionally excluded from the external evidence package.

2. Cloud Inventory

Area	Reported configuration
Cloud providers	Amazon Web Services (AWS) and Google Cloud Platform (GCP)
AWS location	Region <code>us-east-1</code>
GCP location	Region <code>us-east1</code> ; the supplied value <code>us-east1-d</code> is the availability zone
AWS compute	Separate virtual machines for Frontend, Backend/application workloads, VPN access, and MPC node 1
AWS managed data services	Amazon RDS for PostgreSQL and Amazon ElastiCache
AWS secret storage	AWS Secrets Manager
GCP compute	Compute Engine virtual machine for MPC node 2
GCP managed data service	Cloud SQL for PostgreSQL
GCP secret storage	Google Secret Manager
Customer boundary	A partner/customer-managed MPC node and database may participate outside FortVault's AWS and GCP accounts

The AWS account identifier was supplied internally but is redacted from this externally shared document. The reported GCP project name is `fortvault`.

3. Network and Access Boundaries

- AWS workloads are reported to run inside one virtual private cloud (VPC).
- Each AWS workload or managed service uses a dedicated security group.

- Frontend, Backend/application workloads, and MPC node 1 are reported to share one subnet. The VPN server is placed in a separate subnet.
- Administrative access is intended to pass through the VPN server.
- GCP MPC node 2 communicates with its Cloud SQL database and Google Secret Manager.
- MPC nodes communicate across cloud and customer boundaries using mutually authenticated transport. Exact external addresses are excluded.
- AWS uses workload roles for service-to-service access. GCP uses service accounts for deployment and runtime workloads.

The supplied information does not establish which AWS subnet is public, the exact ingress paths, network access-control lists, firewall rules, outbound restrictions, database public-access settings, or whether private service endpoints are used. Those items require sanitized cloud-console evidence.

4. Secret and Identity Management

Application and infrastructure secrets are reported to be stored in AWS Secrets Manager and Google Secret Manager. AWS roles and GCP service accounts are reported for deployment and runtime access.

Required evidence still includes role and service-account inventories, trust policies, least-privilege review, MFA requirements for privileged users, secret rotation settings, access-review records, and confirmation that no production secret is stored in source control or deployment scripts.

5. Deployment and Change Management

Infrastructure is currently configured manually. Infrastructure-as-code is not implemented. This increases the risk of configuration drift and makes repeatable review and approval more difficult.

Recommended improvement: define the production network, compute, databases, caches, secret stores, IAM bindings, backup policies, and logging controls in reviewed infrastructure-as-code. Apply changes through protected branches, peer review, automated validation, and an approved deployment identity.

6. Logging, Monitoring, and Detection

Cloud audit logging and centralized cloud monitoring are reported as not configured. This is a material control gap because privileged actions, configuration changes, service failures, and security events cannot yet be demonstrated through retained cloud evidence.

Priority remediation:

- enable organization/account-level AWS audit logging and retain logs in a protected central destination;
- enable and retain appropriate Google Cloud audit logs, including administrative activity and required data-access events;
- configure AWS and GCP monitoring, availability alarms, database alarms, and security-relevant alerts;
- define log retention, access control, time synchronization, escalation, and incident linkage; and
- test representative alerts and retain sanitized evidence.

7. Current Control Gaps

Gap	Risk	Recommended treatment
No cloud audit logging	Privileged and configuration activity cannot be evidenced reliably	Enable protected AWS and GCP audit logs with approved retention
No centralized monitoring	Availability and security events may not be detected promptly	Implement metrics, alarms, notification routing, and tested escalation
Manual infrastructure	Drift and unreviewed changes are harder to prevent or detect	Adopt reviewed infrastructure-as-code and controlled deployment
Frontend, Backend, and MPC1 share a subnet	Security zones may not be sufficiently isolated even with security groups	Review subnet segmentation and document approved traffic paths
Cloud configuration not independently evidenced	The supplied description cannot prove production settings	Attach sanitized console exports or configuration reports

8. Evidence to Attach

- Sanitized AWS VPC, subnet, route, security-group, and workload inventory exports.
- Sanitized GCP VPC/firewall, Compute Engine, Cloud SQL, and service-account inventories.
- IAM and service-account role summaries with secret values and personal data removed.
- RDS, Cloud SQL, ElastiCache, disk, and secret-store encryption configuration.
- Audit-log and monitoring configuration after remediation.
- Change/deployment procedure and approval evidence.

9. Management Review Required

Before external submission, FortVault should confirm the final workload inventory, public ingress paths, database isolation, customer-managed MPC boundary, and whether Backend, Processing, and Listener share the reported Backend virtual machine. Any screenshots must be reviewed for credentials, private IP addresses, account identifiers, customer information, and internal endpoint names.